

Rapport de Vulnérabilité :

Configuration mTLS MQTT

Date de l'audit : 30 Mars 2026

Cible : Procédure de déploiement mTLS IoT (OpenSSL & Mosquitto)

Niveau de criticité global : ÉLEVÉ (pour un environnement de production)

1. Vulnérabilités Critiques et Élevées

1.1. Clé privée de la Root CA non chiffrée (Critique)

- **Constat :** La commande `openssl genrsa -out ca.key 2048` génère la clé privée de l'Autorité de Certification en clair sur le disque.
- **Risque :** Si un attaquant accède à ce fichier, il compromet l'intégralité de la chaîne de confiance (PKI). Il pourra forger de faux certificats clients et se connecter au broker de manière légitime, ou usurper l'identité du broker.
- **Correction :** Protéger la clé de la CA avec un mot de passe robuste en utilisant un algorithme de chiffrement (ex: AES-256).

```
openssl genrsa -aes256 -out ca.key 4096
```

1.2. Absence d'extensions X.509 v3 et du SAN (Élevé)

- **Constat :** Les certificats sont générés uniquement avec le champ "Common Name" (CN=MQTT-test).
- **Risque :** L'utilisation stricte du CN pour la vérification du nom d'hôte est dépréciée depuis de nombreuses années (RFC 2818 / RFC 6125). Les clients TLS modernes et stricts rejeteront le certificat du broker s'il ne possède pas l'extension **Subject Alternative Name (SAN)** contenant le nom de domaine ou l'IP du broker. De plus, les attributs `basicConstraints` et `keyUsage` sont manquants.
- **Correction :** Utiliser un fichier de configuration OpenSSL (.ext) lors de la signature pour inclure le SAN (ex: `DNS:mqtt.mon-entreprise.com`, `IP:192.168.1.10`) et restreindre l'usage des clés.

2. Vulnérabilités Moyennes

2.1. Longueur de clé inadéquate pour la durée de vie de la CA (Moyen)

- **Constat** : La CA est générée avec une clé RSA de 2048 bits pour une durée de 10 ans (-days 3650).
- **Risque** : RSA 2048 est aujourd'hui le strict minimum acceptable. Pour une racine de confiance censée durer une décennie, la puissance de calcul future rend cette taille de clé vulnérable.
- **Correction** : Utiliser une clé RSA de **4096 bits** pour la CA, ou pivoter vers la cryptographie à courbe elliptique (ECDSA), plus performante pour l'IoT (ex: courbe secp384r1).

2.2. Absence de mécanisme de révocation (Moyen)

- **Constat** : Le TP configure l'authentification client (`require_certificate true`), mais ne prévoit aucun moyen de vérifier si un certificat a été révoqué.
- **Risque** : Dans le monde de l'IoT, le vol physique d'un appareil est courant. Si le périphérique `iot-client-iba` est volé, son certificat reste valide et l'attaquant a un accès permanent au broker MQTT.
- **Correction** : Mettre en place une **CRL (Certificate Revocation List)** gérée par OpenSSL et l'intégrer dans la configuration Mosquitto avec la directive `crlfile /etc/mosquitto/certs/crl.pem`.

2.3. Paramètres TLS permissifs sur le Broker (Moyen)

- **Constat** : La configuration Mosquitto active les certificats mais ne force pas la version du protocole TLS ni les suites cryptographiques.
- **Risque** : Mosquitto pourrait accepter des connexions utilisant des versions obsolètes et vulnérables de TLS (comme TLS 1.0 ou 1.1) ou des chiffrements faibles, exposant les communications à des attaques de type "Downgrade".
- **Correction** : Ajouter les directives suivantes dans la configuration Mosquitto :

```
tls_version tlsv1.2 (ou tlsv1.3)
```

3. Faiblesses Opérationnelles

3.1. Gestion des permissions et chemins de fichiers (Faible)

- **Constat** : Les fichiers sont générés dans le dossier personnel de l'utilisateur (~/.IoT/...) avec des droits stricts (chmod 600). Cependant, la configuration de Mosquitto pointe vers /etc/mosquitto/certs/.
- **Risque** : Lors du déplacement des fichiers, si le propriétaire (chown) n'est pas correctement défini sur l'utilisateur exécutant le service Mosquitto (généralement mosquitto), le broker plantera au démarrage par manque de droits de lecture sur broker.key.
- **Correction** : S'assurer que les clés de production appartiennent au service dédié :

```
chown mosquitto:mosquitto /etc/mosquitto/certs/broker.key
```

Résumé

Ce TP est parfait pour comprendre la **mécanique** de création et de validation d'une chaîne de confiance pour le MQTT. Cependant, avant de qualifier cette infrastructure "pour la production", il est impératif d'intégrer le chiffrement de la clé CA, l'ajout du SAN dans les certificats, et la gestion des révocations (CRL) pour gérer le cycle de vie des objets connectés.